

W1 PROFESSIONAL PRACTICE
IT professionalism: competent, ethical, accountable practice in org context; protect trust, data, users, public good. Professional qualities: honesty, responsibility, confidentiality, competence, punctuality, respect, leadership, continuous learning. Answer frame define concept → apply to scenario → risk/benefit → mitigation/decision. Code of conduct: expected behaviour standard, code of ethics: principles for resolving value conflicts. ACS values: public interest; quality of life; honesty; competence; professional development; professionalism. Ethical dilemma: identify stakeholders; facts/evidence; duties/laws; options; consequences; ACS principle; justified action. Non-technical skills: communication, teamwork, conflict resolution, negotiation, stakeholder mgmt, critical thinking. Diversity in tech: broader talent pool, better problem framing, less biased design; needs inclusion not tokenism. Org structure: hierarchical-centralised; flat-fast comms; matrix=dual reporting; functional-specialists; divisional-product/region. Common exam traps: professionalism ≠ only technical skill; confidentiality ≠ secrecy when harm/legal duty exists. Scenario phrase act honestly, escalate through proper channel, document evidence, protect affected users, avoid speculation. Career progression: junior analyst → specialist/consultant → architect/manager/CISO; grows via responsibility, certs, evidence. Current challenges: AI threats, cloud misconfig, remote work, privacy/data sovereignty, supply-chain, skills shortage. Professional writing: clarity=easy meaning; precision=exact claims/data; brevity=no repetition; objectivity=evidence over hype. Improve writing: define audience, state purpose first, cite sources, replace vague adjectives, cut duplicate benefits, use measurable KPI. Professional judgement: choose defensible action under uncertainty; state assumptions and escalation path. Trust signals: transparency, documentation, competence limits, privacy-by-default, respectful conduct. Career answer: role path + required capability + example responsibility + current industry pressure. Bad answer: “be professional” without naming confidentiality, accountability, competence or stakeholder impact.
W2 IT VALUE ALIGNMENT
Business goal: broad desired direction; objective: specific measurable target; strategy: plan to achieve objectives. SMART objective specific, measurable, achievable, relevant, time-bound; e.g. reduce checkout failures 30% in 6 months. IT investment value: value = benefits - costs - risks; include tangible + intangible + option value + compliance. Alignment: business strategy → capabilities → IT operating model → portfolio → KPI feedback. Value types: revenue growth, cost reduction, risk reduction, compliance, customer experience, agility, data insight. IT operating model: how IT decisions, services, platforms and roles are organised to deliver business capabilities. Weak operating model signs: duplicate apps, unclear ownership, slow change, poor integration, local optimisation, no KPI link. Enterprise Architecture: blueprint linking business/data/app/tech domains; supports consistency, integration, compliance, change. TOGAF domains: Business=strategy/process/org; Data=logical/physical assets; Application=systems/interactions; Technology=infrastructure. EA benefits improved decisions, adaptability, reduced redundancy, resource optimisation, cross-org collaboration, single source of info. Business case: problem, options, costs, benefits, risk, governance, timeline, KPI, recommendation. CIO role: align digital initiatives, portfolio governance, data/security strategy, stakeholder translation, innovation risk balance. Case answer: link each IT feature to business capability and objective, not just technology novelty. Cloud value: scalability, OPEX, speed, managed services; risks: lock-in, privacy, outage, shared responsibility. Cloud models: IaaS=max control/no hardware; PaaS=dev platform; SaaS=business app; hybrid=control + elasticity. Capability: what org must be able to do; IT systems enable but do not equal capability. Benefits realisation: baseline, target, owner, measure, review, corrective action after go-live. Architecture debt: duplicate data, brittle integration, vendor lock-in, no standard platform, hidden security gaps. Objective example: increase active riders 20% by S2 via app reliability, card integration and targeted incentives.
W3 LIFECYCLE & PM
Continuous IT lifecycle: plan → build → test → deploy → operate → monitor → improve. Waterfall: stable reqs, sequential, heavy upfront design; weak under change/late feedback. Agile: iterative, customer feedback, reprioritisation; needs engaged PO, disciplined backlog, working increments. DevOps: dev+ops collaboration, CI/CD, automation, telemetry; DevSecOps: security built into pipeline. Waterfall vs Agile flexibility low/high; feedback late/continuous; delivery big-bang/incremental; risk late/early visible. ITSM: manages reliable services; incident, problem, change, request, SLA; complements Agile/DevOps with operational control. Project mgmt: scope/time/cost/quality/resources/risk; change mgmt: people adoption and behaviour transition. Triple constraint

scope ↔ time ↔ cost; quality/risk are affected by trade-offs. PM planning: WBS; dependencies; effort; resources/duration; budget; risk reserve; stakeholder comms. WBS: deliverable-oriented decomposition; too coarse=poor control, too fine=admin overhead. Estimation: expert judgement, analogy, sum-of-parts, component matrix, algorithmic, function points. duration = effort/resources; cost = ∑(hours × rate) + hardware/software/buffer Risk responses: avoid, mitigate, transfer, share, accept; always link to likelihood and impact. Failure causes: incomplete reqs, unrealistic schedule, insufficient resources, poor comms, scope creep, weak governance. Exam scenario: choose lifecycle by uncertainty, regulation, feedback need, release cadence, security/compliance burden. Definition of Done: code, test, docs, security checks, acceptance criteria, deployability complete. DevSecOps controls: SAST/DAST, dependency scan, secrets scan, policy-as-code, IaC review, audit trail. Change control: request, impact, approval, schedule, implement, verify, communicate, close. Lifecycle fit: regulated safety-critical work may need hybrid governance even with Agile teams.
W4 COMM & STAKEHOLDERS
Stakeholder: anyone with power, interest, influence, expertise, risk exposure, or adoption role. Stakeholder analysis: identify → map power/interest → needs/resistance → comms plan → feedback loop. Power-interest: high/high=manage closely; high/low=keep satisfied; low/high=keep informed; low/low=monitor. Communication barrier: jargon, culture/time zone, authority gap, low technical literacy, channel mismatch, ambiguity. For senior non-technical stakeholder translate risk into business impact, options, trade-offs, decision needed. Collaboration: shared goal, clear roles, psychological safety, decision rules, conflict handling, documentation. Conflict resolution: clarify interests, separate people/problem, evidence, options, agreed action, follow-up. Negotiation: BATNA, priorities, constraints, concessions; use objective criteria and traceable decision rationale. Team stages: forming, storming, norming, performing, adjourning; leader adapts support/directiveness. Distributed teams: async notes, decision log, overlapping hours, explicit owners, demos, issue escalation path. Report quality: clear structure, concise executive summary, evidence, assumptions, limitations, recommendations. Writing defects: unclear=ambiguous; imprecise=vague metrics; wordy=repetition; subjective=hype/no evidence. Rewrite rule replace “better security” with “MFA + logging reduces unauthorised access risk for privileged accounts”. Meeting update: status, progress, risks, decisions needed, next steps, owner/date. Exam tip: solve the human communication problem, not just the technical symptom. RACI: responsible, accountable, consulted, informed; prevents ownership gaps and duplicate decisions. Comms channel: dashboard=status; workshop=alignment; email=record; demo=feedback; escalation=risk decision. High power/low interest: short brief, business risk, decision options, no technical overload, periodic check-in. Clarity test: reader can state the recommendation, reason and required action after one pass.
W5 EVIDENCE & ESTIMATION
Evidence-based practice: decisions from credible data, research, standards, stakeholder evidence, and measured outcomes. Research question: clear population/context, variable, outcome; avoid leading or unfalsifiable questions. Reliability: consistency of measure; same method under same conditions yields similar results. Validity: measures intended construct accurately; a reliable measure can be invalid if consistently wrong. Reliability vs validity reliable = valid; valid usually requires sufficient reliability. Evidence quality: source authority, method transparency, sample bias, recency, relevance, triangulation. Metric: raw measure; KPI: metric tied to objective and decision threshold. KPI design: objective → behaviour to influence → metric → target → owner → review cadence. Project estimates: size, effort, resources, duration, cost; update estimate as uncertainty reduces. Function point: estimates system size from user-visible functions, inputs/outputs/files/interfaces/queries. Estimation pitfalls: optimism bias, anchoring, hidden integration, ignored non-functional reqs, no contingency, poor historical data. Cost elements: labour, licenses, cloud, hardware, training, migration, testing, security, support, contingency. Investigative research: define claim; gather evidence; evaluate credibility; compare alternatives; report limitations. Data quality: accuracy, completeness, consistency, timeliness, validity, uniqueness, lineage. Case answer quote the scenario evidence, state assumption, choose method, justify why it fits. Triangulation: combine interviews, logs, benchmark, survey, financial data to reduce single-source bias. Validity types: construct, internal, external, criterion; explain only those relevant to scenario. Estimate update: initial ROM → refined after WBS/prototype → baseline → variance control. KPI pitfall: easy-to-measure metric may distort behaviour if not tied to real

objective. W6 IT GOVERNANCE IT governance: decision rights + accountability ensuring IT sustains and extends org strategy/objectives. COBIT: governance/management objectives; aligns IT with enterprise goals, controls, metrics. ITIL: IT service management; incident/problem/change/release/SLA/service catalog; value co-creation. ISO 27001: ISMS, risk-based security controls, certification; NIST CSF: identify/protect/detect/respond/recover. Framework choice COBIT=governance alignment; ITIL=service operations; ISO/NIST=security mgmt; TOGAF=architecture. Audit: independent review providing assurance on controls, risk, compliance and improvement actions. Audit areas: physical/environment, system admin, application, network security, BCP/DR, data integrity. Risk-based audit: inventory IS; identify critical functions; assess risk; rank systems; plan priority/resources/schedule. IT audit process: prepare, kickoff, fieldwork, findings/report, corrective action, follow-up/certification. Control: preventive, detective, corrective; admin/technical/physical; manual/automated. Governance mechanisms: steering committee, architecture board, risk register, policies, portfolio gaps, KPI dashboards. Maturity model: initial/ad hoc → repeatable → defined → managed → optimising. Data governance: ownership, stewardship, quality, access, retention, lineage, privacy, metadata. Exam phrase governance is not doing IT work; it sets accountability, decision criteria, monitoring and control. Cloud governance: shared responsibility, vendor due diligence, data location, IAM, logging, exit plan, SLA. Decision rights: who can approve spend, risk acceptance, architecture exception, data access. Policy vs standard vs procedure: what/why; mandatory measurable rule; step-by-step execution. Control test: design effectiveness + operating effectiveness + evidence + remediation owner/date. Audit answer: include scope, criteria, evidence, findings, risk rating, corrective action.
W7 CHANGE MANAGEMENT
Organisational Change Mgmt: people-side of change; ensures adoption, usage, benefits realisation. ADKAR Awareness, Desire, Knowledge, Ability, Reinforcement; missing step predicts adoption failure. Awareness: why change; Desire: personal motivation; Knowledge: how; Ability: perform; Reinforcement: sustain. Resistance causes: fear, loss of status, no trust, poor training, workload, unclear benefits, bad prior change. OCM plan: stakeholder impact; sponsor coalition; comms; training; readiness; adoption metrics; reinforcement. McKinsey 7S: strategy, structure, systems, shared values, skills, style, staff; align hard-soft elements. Kotter: urgency, coalition, vision, enlist, remove barriers, wins, sustain, anchor. Project mgmt vs change mgmt: PM delivers solution; OCM enables people to use solution and realise value. Business readiness: process, data, roles, support, policy, training and incentives ready for go-live. Underutilised ADKAR in scenario low usage often = Desire/Ability/Reinforcement, not just Knowledge. Adoption metric: login/use rate, task completion, error rate, support tickets, satisfaction, business KPI. Leadership actions: visible sponsorship, decision clarity, remove blockers, model behaviour, allocate training time. Change impact assessment: who changes, what changes, when, degree, risk, support needed. Exam tip: if staff keep spreadsheets after ERP, discuss incentives, workflow fit, training, data migration, reinforcement. Answer template: diagnose ADKAR gap → scenario evidence → targeted intervention → measurable adoption outcome. Sponsor: visible senior leader who legitimises change, removes blockers and reinforces priorities. Training types: role-based, just-in-time, hands-on, super-user network, job aids, refreshers. Readiness check: process mapped, roles assigned, data migrated, support ready, users trained, comms sent. OCM KPI: adoption + proficiency + business outcome; usage alone may hide poor quality.
W8 QA & TESTING
QA: process-focused prevention; QC: product/result inspection; both support quality. Testing: finding defects and evidence against quality criteria; cannot prove absence of all defects. Black-box: input/output behaviour; white-box: code/path/logic; UAT: user/business acceptance. Unit: component; integration: interfaces; system: whole system; regression: old behaviour after change. Load vs stress vs soak load=expected traffic; stress=beyond limits; soak=long-duration stability/leaks. Non-functional tests: performance, security, usability, accessibility, compatibility, reliability, recoverability. Test plan: scope, risks, environment, data, roles, schedule, entry/exit criteria, defect workflow. Defect lifecycle: detect, log, triage, assign, fix, retest, regression, close.

Quality attribute: reliability, availability, maintainability, usability, security, performance, scalability. Availability uptime; reliability: failure frequency; resilience: recover/adapt under disruption. QA standards: ISO9001 process quality; ISO/IEC 25010 software product quality model. Agile QA: shift-left, automated tests, definition of done, CI feedback, exploratory testing, user demos. Acceptance criteria: testable condition of satisfaction; scenario-based and measurable. Bug report: title, environment, steps, expected, actual, evidence, severity, priority. Exam scenario: choose testing type by risk: market change/user needs=UAT/iterative; traffic/load; stability=soak; break point=stress. Severity vs priority: user/business impact vs urgency/order to fix; not always the same. Entry criteria: build available, env ready, data ready; exit criteria: pass tests, critical defects closed. Performance test: workload model, baseline, test, bottleneck analysis, tune, retest, monitor in prod. UAT trap: users validate business fitness, not internal code correctness.
W9 SECURITY MGMT I
Information security: protect info assets; cybersecurity: protect digital systems/networks; data privacy: lawful/ethical personal data handling. CIA confidentiality, integrity, availability; extend with authenticity, accountability, non-repudiation. Threat: potential cause; vulnerability: weakness; risk: likelihood × impact; control: reduces likelihood/impact. Social engineering: manipulates people; phishing, pretexting, baiting, quid pro quo, tailgating. APT: skilled, persistent, stealthy, targeted, multi-stage attack seeking strategic objective. STRIDE: spoofing, tampering, repudiation, information disclosure, DoS, elevation of privilege. Threat modelling: assets, entry points, trust boundaries, threats, controls, residual risk. Controls: MFA, least privilege, patching, encryption, backups, logging/SIEM, segmentation, awareness, secure config. Least privilege users/services get only permissions needed, for as long as needed. Ransomware response: isolate, activate IR/BCP, preserve evidence, restore clean backup, notify as required, learn. Security testing: vulnerability scan, penetration test, code review, SAST/DAST, dependency scan. Cloud shared responsibility: provider secures cloud; customer secures identity, data, config, workloads by service model. Zero trust: never trust by network location; verify explicitly, least privilege, assume breach. Incident response: prepare, detect/analyse, contain, eradicate, recover, post-incident review. Exam trap: hiding a breach may violate law, ethics and public interest even if reputationally convenient. Attack surface: exposed systems, identities, APIs, vendors, users, data flows attackers can target. Phishing defences: MFA, filtering, awareness, reporting button, domain controls, playbooks, simulations. Log triage: signal, correlate, scope, contain, preserve evidence, communicate, remediate. Risk statement: threat actor exploits vulnerability causing impact to asset; control reduces likelihood/impact.
W10 SECURITY MGMT II
BCP: keep critical business functions operating; DR: restore IT systems after disruption. BCP vs DR BCP is business continuity; DR is IT recovery subset; both use risk/BIA. BIA: identify critical processes, dependencies, RTO, RPO, impact over time, priority. RTO: max tolerable time to restore; RPO: max tolerable data loss. Security plan: asset inventory, classification, risk assessment, control selection, roles, monitoring, response, review. Asset protection: classify, owner, access control, encryption, DLP, backup, retention, disposal. Privacy principles: purpose limitation, consent/lawful basis, minimisation, accuracy, security, retention, rights. GDPR-like duties: lawful basis, transparency, data subject rights, breach notification, DPIA, processor contracts. Hybrid cloud security: data location, IAM federation, network segmentation, encryption, logging, vendor SLA, exit. Security governance policy + risk appetite + standards + monitoring + accountability + continuous improvement. Framework mapping: NIST CSF=Identify/Protect/Detect/Respond/Recover; ISO27001=ISMS; COBIT=governance. Access control: RBAC=role; ABAC=attributes/context; PAM=privileged accounts. Backup strategy: 3-2-1 copies, offline/immutable, tested restore, retention, encryption, responsibility. Controls by CIA: confidentiality=MFA/encryption; integrity=hash/change control; availability=redundancy/DR. Scenario answer: asset + threat + vulnerability + impact + control + residual risk + owner. DPIA: privacy impact assessment for high-risk personal data processing; identifies mitigations early. Data classification: public, internal, confidential, restricted; drives access/encryption/retention. DR test: tabletop, partial restore, full failover; record gaps and update

runbook. Hybrid cloud trap: keeping data on-prem does not remove identity, integration or monitoring risk.
W11 ETHICS & RESPONSIBILITY
Ethics: reasoned principles of fairness, accountability and justice; public interest. Individual ethics: professional impact, justice, equity, common good. Public interest: prioritise safety narrow employer/client benefit. Ethical frameworks: duty/deontonics, justice/fairness, virtue/practical ethics. AI ethics bias, transparency, accountability, contestability. Data breach dilemma: confidentiality vs public interest; duty to affected users/law; escalate and disclose through proper process. Ethical analysis: stakeholders; harms/benefits; rights/duties; options; ACS principle; justified recommendation. Stakeholders: users, clients, employer, team, regulators, vulnerable groups, public, future maintainers. Algorithmic bias: unfair outcomes from data, design, proxies, deployment context; mitigate via testing, monitoring, governance. Privacy vs security: security protects data, privacy governs appropriate collection/use/sharing. Professional accountability: own advice, document limits, avoid misleading claims, maintain competence, report serious risk. Good answer not “is it legal?” only; discuss professional responsibility and public impact. Sanctions: admonition, reprimand, fine, suspension, expulsion, CPD, certification withdrawal. Responsible innovation: anticipate impacts, include stakeholders, test assumptions, monitor harms, adapt. Exam phrase: recommend proportionate action that protects users while following organisational/legal escalation channels. Proportionality: controls and disclosure should match risk, harm, legal duty and stakeholder vulnerability. Fairness mitigations: representative data, bias testing, explainability, human review, appeal path, monitoring. Ethical recommendation: principle + affected stakeholder + concrete action + why alternative is weaker. Public good: do not let employer reputation outweigh foreseeable harm to users or society.
W12 DATA & BI DECISIONS
Data: raw facts; information: processed meaningful data; knowledge: interpreted info enabling action. Data warehouse: integrated, historical, subject-oriented repository for reporting/analytics; supports consistent decisions. ETL Extract from sources; Transform clean/integrate/standardise; Load into warehouse/mart. ELT: load before transform in scalable platforms; useful for big data/cloud lakehouse. BI tools/processes turning data into dashboards, reports, OLAP, insights for decision-making. OLAP ops: slice/filter; dice=subcube; drill-down=detail; roll-up=aggregate; pivot=rotate dimensions. Dashboard design: audience, KPI, threshold, trend, comparison, exception, action owner. Analytics: descriptive what happened; diagnostic why; predictive what likely; prescriptive what to do. Data quality in BI: poor input creates wrong confidence; check accuracy, completeness, timeliness, consistency. Retail BI example warehouse integrates POS/inventory; BI shows stockouts; KPIs stockout rate, turnover, fulfilment time. Decision risks: bias, correlation/causation error, stale data, missing context, dashboard theatre, privacy. UI role: makes insights usable; supports interpretation, drill-down, accessibility, error prevention, action. Data-driven decision: define objective; collect quality data; analyse; interpret; decide; monitor KPI; refine. Exam answer: tie BI feature to business objective and operational action, not just “shows data”. Final pattern scenario-specific concise answers beat generic definitions; use terms + evidence + recommendation. Single source of truth: governed common data definitions; reduces conflicting reports and decision friction. BI KPI examples: stockout rate, inventory turnover, fulfilment lead time, forecast error, margin, churn. Dashboard actionability: threshold, owner, drill-down, trend, exception, next action. Analytics trap: predictive score is not decision; include context, ethics, uncertainty and monitoring.

USYD各科往届题库

